Community Open Source UNICA

Versione 1.0 – 14 ottobre 2026

1. Premessa

La soluzione contabile denominata "UNICA" è una soluzione software realizzata dal CSI-Piemonte, in coerenza con il **D.Lgs. 118/2011** per la **contabilità della Pubblica Amministrazione**.

UNICA è strutturata in un insieme di componenti software rilasciati in open source dal titolare CSI-Piemonte, su Developers Italia: https://developers.italia.it/it/software/9cb6419d-b237-40f1-8aa2-f7517d239458, su GitHub: https://github.com/unica-open/, con licenza EUPL 1.2, in ossequio alle linee guida nazionali AgID sul riuso del software pubblico.

Il CSI intende promuovere la collaborazione di soggetti pubblici e privati interessati a fare ulteriormente evolvere la soluzione open source a partire dal suo adeguamento ai nuovi principi di contabilità economico-patrimoniale denominati **ACCRUAL (Riforma 1.15 del PNRR "Riforma delle norme di contabilità pubblica")** al fine di realizzare una soluzione adeguata alle nuove esigenze, preservando il valore degli investimenti finora realizzati e sfruttando le logiche della condivisione in open source secondo il modello della community aperta.

La community UNICA Open Source è un programma operativo finalizzato all'evoluzione complessiva della soluzione UNICA, con riferimento sia alla contabilità finanziaria sia alla contabilità economico-patrimoniale.

Il modello di governance proposto per UNICA si fonda su un approccio aperto e collaborativo, in cui la partecipazione della community si integra con la responsabilità finale, tecnica e legale, del Maintainer, a tutela della qualità, della sicurezza e della sostenibilità del programma.

Ai fini del presente documento:

- "**UNICA**" indica la suite software;
- "**Programma UNICA**" indica l'iniziativa organizzativa e di governance finalizzata alla sua evoluzione;
- "**Community UNICA**" indica l'insieme dei soggetti che

partecipano al Programma secondo le presenti regole.

Il presente documento costituisce il manifesto di governance della community open source UNICA.

2. Principi ispiratori

Il modello UNICA coniuga apertura e collaborazione con un presidio organizzativo volto a garantire qualità, continuità e interesse pubblico.

La community UNICA è costruita secondo un modello di collaborazione aperta, ispirato alle grandi community open source internazionali, in cui il valore del sorgente cresce proprio in funzione della comunità che lo usa e collabora al suo sviluppo. La community non condivide né promuove logiche di mercato, né di erogazione di servizio a terzi, che rimangono attività non vietate ma esterne al perimetro di competenza della community.

Fine ultimo della community non è soltanto realizzare software funzionante, ma costruire nel tempo un ecosistema stabile, inclusivo e sostenibile, capace di attrarre competenze, stimolare la condivisione e garantire migliore continuità evolutiva.

La community open source di UNICA si fonda sui seguenti **principi guida**:

- **Modello di collaborazione aperta**: Il modello si basa sulla trasparenza dei meccanismi di contribuzione, sulla possibilità per chiunque di partecipare e contribuire in modo aperto e distribuito, secondo livelli di contribuzione e impegno progressivi;
- **Partecipazione e contributi**: la comunità è aperta, nei termini e modi precisati di seguito a tutti i soggetti, pubblici e privati, che siano interessati e aderiscano alle regole della community stessa;
- **Processi decisionali trasparenti e coerenza di governance**: le decisioni seguono principi di trasparenza e condivisione delle esigenze, con l'obiettivo di un processo decisionale sostenibile. Per garantire una roadmap coesa e un governo efficace ed efficiente, il - CSI conserva il ruolo di Maintainer nel rispetto della suddetta trasparenza;
- **Innovazione e sostenibilità**: Il modello UNICA coniuga l'apertura e la collaborazione tipiche delle community open source con un presidio organizzativo volto a garantire continuità, qualità e tutela dell'interesse pubblico, oltre a un

modello di innovazione aperto anche a nuovi contributori;

- **Software libero**: tutto il codice sorgente della comunità, indipendentemente dal contributore, viene conferito e pubblicato con licenza open source, accessibile a tutti nel rispetto dell'art. 69 del d.lgs. 82/2005 (CAD);
- **Valore del riuso**: La community UNICA contribuisce a incarnare il valore del riuso, come definito nelle Linee Guida AgId, permettendo a tutte le PA interessate di riutilizzare quanto sviluppato senza costi di licenza, contribuendo al miglioramento comune;
- **Sostenibilità del sistema:** la community si fonda anche sulla sua capacità di garantire evoluzione continua riducendo la dipendenza da singoli fornitori;
- **Assenza di logiche di mercato**: La partecipazione alla Community UNICA non costituisce titolo preferenziale né diretto né indiretto nell'ambito degli eventuali affidamenti disposti dal CSI.

La community opera quindi come spazio di confronto tecnico e istituzionale, nel quale il contributo di ciascun partecipante concorre al miglioramento complessivo della soluzione.

3. Ambito del programma UNICA

Il programma UNICA comprende un insieme coerente di componenti software open source dedicate alla gestione della contabilità pubblica, con particolare riferimento ai moduli **Accrual**, **Inventari** e all'evoluzione della contabilità finanziaria 118/2011, oggi basata sul modulo Contabilia. I moduli non ancora pubblicati entreranno formalmente nel perimetro del programma UNICA al momento della loro disponibilità nei repository ufficiali.

Contabilia copre i processi di contabilità finanziaria armonizzata, assicurando l'aderenza ai principi ARCONET e ai modelli previsti dalla normativa vigente, mentre **Accrual** è finalizzato alla gestione delle scritture economico-patrimoniali, delle riconciliazioni e dei processi di chiusura. **Inventari** è un modulo finalizzato alla gestione degli inventari economico-patrimoniali utili per la gestione Accrual del patrimonio di un ente che possa essere anche esteso con funzionalità proprie della gestione ordinaria del singolo bene.

UNICA è aperto a evolversi, anche con nuovi moduli, che saranno valutati nel contesto degli strumenti di governo e secondo le relative regole (rif. Par 10) a condizione che conservino coerenza con il dominio funzionale della contabilità pubblica e con i principi architetturali e di governance come condivisi in sede di adesione.

L'ambito di UNICA non include né può includere componenti proprietarie non redistribuibili e richiede il conferimento dei contributi, a qualsivoglia livello, con modalità di licensing compatibili con il rilascio della suite nel suo complesso, preferibilmente, sotto licenza EUPL 1.2 o successive versioni. Eventuali verticalizzazioni specifiche di interesse di un singolo soggetto potranno essere inserite nella suite ove valutate di interesse ai sensi dell'art. 10, ma sempre e solo secondo logica e sotto licenza open source compatibile. Eventuali modifiche future della licensing strategy saranno eventualmente definite e condivise in seno alla community stessa.

4. Ruoli nella Community

4.1 Struttura della community e criteri di partecipazione

La community UNICA è aperta alla partecipazione di **contributori aderenti (di seguito, Aderenti)** e di **contributori esterni (di seguito, Contributori)** che intendano collaborare allo sviluppo del software. Aderenti e Contributori possono avere personalità giuridica di diritto pubblico o privato (a titolo di esempio Enti pubblici economici e non, aziende private, atenei e università, centri di ricerca), nonché essere anche singoli individui.

L'accesso alla Community avviene secondo criteri aperti, trasparenti e non discriminatori, nel rispetto delle regole di governance e contribuzione previste dal presente documento.

Gli Aderenti acquisiscono detto ruolo a seguito della presentazione della richiesta di adesione e della verifica prevista al paragrafo 4.5, previa accettazione formale, secondo le proprie regole interne di ratifica, delle regole di funzionamento della Community, che definisce le modalità e condizioni in base a cui gli Aderenti possono partecipare al progetto, contribuendo non solo con attività di sviluppo di codice, ma anche con competenze funzionali, test, documentazione o supporto alla governance (v. art. 5).

I Contributori possono partecipare senza alcun vincolo formale, proponendo miglioramenti, segnalando problemi o inviando contributi puntuali, anche tramite

gli strumenti messi a disposizione della piattaforma di pubblicazione GitHub.

In entrambi i casi, la partecipazione è regolata da principi di trasparenza e responsabilità: tutti i contributi avvengono tramite canali pubblici e documentati, e sono soggetti alle stesse regole di revisione e accettazione, per ampliare l'ecosistema mantenendo al contempo elevati standard qualitativi e riducendo il rischio di frammentazione o lock-in tecnologico.

4.2 Maintainer

Il **Maintainer** di UNICA è il **CSI Piemonte (o CSI)**, supportato dal proprio **Open Source Program Office (OSPO)** come presidio organizzativo, tecnico e legale dell'iniziativa. Il Maintainer è responsabile del progetto UNICA nel suo complesso e ne governa l'evoluzione, esercitando un ruolo di garanzia e di governo volto ad assicurare la qualità, la sicurezza e la sostenibilità e coerenza della soluzione nel tempo.

In particolare, il Maintainer:

- raccoglie le adesioni alla community e verifica il rispetto delle regole di partecipazione;
- governa l'evoluzione complessiva della soluzione, assicurandone la coerenza architetturale e normativa;
- garantisce la qualità del codice, la sicurezza e la compliance legale, anche attraverso il supporto dell'OSPO e delle strutture competenti;
- coordina i processi di rilascio del software e la gestione dei repository ufficiali;
- supervisiona i contributi e i processi di integrazione del codice, assicurando trasparenza e tracciabilità;
- gestisce le criticità, in particolare per gli aspetti di sicurezza, licensing e conformità normativa:
- cura la gestione del nome, del logo e degli altri segni distintivi utilizzati dal programma UNICA, definendone le modalità di utilizzo e pubblicandone le relative regole.

Il Maintainer esercita tali responsabilità in coerenza con gli indirizzi strategici definiti dal Technical & Community Steering Committee (TCSC) e nell'interesse complessivo della community, ferma restando la responsabilità di coordinamento e indirizzo tecnico della soluzione.

Contributori e Aderenti mantengono la titolarità dei diritti sui propri contributi. L'invio e relativa accettazione nel sorgente di UNICA di codice, documentazione o altri artefatti, da parte tanto di Contributori che

di Aderenti, è sempre e comunque subordinata al rilascio di quanto così condiviso sotto licenza aperta compatibile con la licenza della soluzione UNICA nel suo complesso e della relativa documentazione (ad oggi, EUPL 1.2 per il codice, licenza Creative Commons BY 4.0 per la documentazione) che permetta al Maintainer e alla community l'utilizzo, la modifica, l'integrazione e la distribuzione del contributo nell'ambito della soluzione UNICA, in coerenza con la licenza open source adottata dal programma.

Restano in ogni caso riconosciuti ai contributori i diritti morali d'autore sui propri contributi, in particolare il diritto alla paternità dell'opera, garantito attraverso adeguate forme di attribuzione (quali storico delle versioni, file AUTHORS o documentazione di progetto).

L'accettazione del contributo non comporta trasferimento esclusivo dei diritti al Maintainer, ma autorizza l'inclusione, la modifica e la redistribuzione del contributo nell'ambito del programma UNICA secondo la licenza applicabile.

Il Maintainer conserva un diritto di veto, da esercitare in via eccezionale e con adeguata motivazione documentata, rispetto all'inserimento di contributi nel sorgente della soluzione, nei casi in cui sussistano motivate ragioni di coerenza tecnica, sicurezza, conformità normativa o sostenibilità complessiva del programma.

Il Maintainer in ogni caso esercita tali poteri anche al fine di favorire la crescita della community e la progressiva distribuzione delle responsabilità tra i partecipanti, in collaborazione con il TCSC, secondo un modello aperto, trasparente e sostenibile.

4.3 Technical & Community Steering Committee (TCSC)

Il **Technical & Community Steering Committee** definisce gli indirizzi strategici del programma, assicurando il coinvolgimento e l'equilibrio tra gli Aderenti della community.

Il rapporto tra Maintainer e TCSC si fonda su un principio di collaborazione e complementarità: il TCSC contribuisce all'indirizzo strategico del programma, mentre il Maintainer ne garantisce la coerenza tecnica, normativa e di sicurezza.

Eventuali elementi di disallineamento sono gestiti attraverso momenti di confronto e riesame condiviso, fermo necessariamente restando il ruolo del Maintainer come sopra delineato.

Ai fini della presente governance, il TCSC svolge funzioni di indirizzo strategico, proposta, valutazione e approvazione delle

principali linee evolutive del programma, mentre il Maintainer assicura l'attuazione delle decisioni e ne verifica la coerenza tecnica, normativa, di sicurezza e di sostenibilità. Le decisioni del TCSC sono pertanto attuate dal Maintainer, salvo esercizio motivato del diritto di veto nei casi previsti dal presente documento.

Il Technical & Community Steering Committee è costituito dall'insieme degli Aderenti che partecipano alla evoluzione del software e della community i cui rappresentanti hanno diritto di voto per scelte di evoluzione e revisione del software. Ciascun Aderente partecipa al TCSC tramite uno o più rappresentanti designati secondo le proprie modalità organizzative. Le modalità di esercizio del diritto di voto e l'eventuale attribuzione di pesi differenziati sono disciplinate dal documento di governance del TCSC.I compiti principali sono:

- esprimere approvazione sulla nomina dei responsabili dei singoli progetti/moduli e fornire pareri al Maintainer circa la loro eventuale revoca;
- definire e approvare gli indirizzi della **roadmap** evolutiva del programma;
- valutare e deliberare le **RFC (Request For Change)** e stabilire gli indirizzi evolutivi conseguenti;
- contribuire alla risoluzione dei conflitti tecnici o di indirizzo, ferma restando la responsabilità finale del Maintainer nei casi che incidono sulla sicurezza, compliance o coerenza tecnica;
- validare l'ingresso di nuovi progetti/moduli nel programma UNICA.
- valutare periodicamente l'andamento delle collaborazioni e l'adeguatezza delle regole di governance, anche ai fini dell'eventuale proposta di nomina o revisione dei Module Lead.

Le modalità di funzionamento del TCSC possono prevedere anche forme di ponderazione del diritto di voto, basate sul livello di partecipazione e contribuzione alla community, secondo quanto meglio definito nel relativo documento di governance.

Le decisioni del TCSC hanno natura di indirizzo strategico e sono attuate dal Maintainer, che ne verifica la coerenza tecnica, normativa e di sicurezza, con possibilità di veto motivato.

Le valutazioni relative alla sostenibilità delle iniziative sono finalizzate a favorire il coordinamento tra gli Aderenti e non incidono sulle modalità con cui ciascun Aderente gestisce autonomamente eventuali aspetti economici o contrattuali, nel rispetto delle normative applicabili.

Le decisioni del Technical & Community Steering Committee sono **pubbliche e motivate**.

Il CSI, quale titolare della suite nel suo complesso e Maintainer, conserva un diritto di veto rispetto alle decisioni del TCSC, con obbligo di motivazione.

4.4 Responsabili di Progetto / Module Lead

Ogni progetto del programma UNICA, relativo alla creazione di un nuovo modulo, all'evoluzione di un modulo esistente o allo sviluppo di un suo sottomodulo, è affidato a un **Responsabile di Progetto** o *Module Lead*, approvato dal Technical & Community Steering Committee.

Il Responsabile di Progetto:

- coordina lo sviluppo tecnico del modulo/sottomodulo;
- cura backlog, issue e pull request;
- propone rilasci e roadmap di dettaglio;
- funge da punto di riferimento per la community del modulo/sottomodulo.
- coordina le attività progettuali e contribuisce alla pianificazione delle risorse necessarie, in coerenza con le indicazioni del TCSC e sotto il coordinamento del Maintainer.

Il ruolo può essere **revocato** dal Maintainer d'intesa con il TCSC, con comunicazione motivata scritta nei seguenti casi:

- Mancato rispetto dei tempi e degli standard qualitativi nella gestione del progetto;
- Comportamenti illeciti o non conformi all'interno della community;
- Ricezione di segnalazioni da contributori interni o esterni, che dovranno essere analizzate e verificate.

4.5 Aderenti

Gli Aderenti sono soggetti che a diverso titolo sono interessati a contribuire attivamente, come da par. 5.1.

Gli Aderenti partecipano alla governance del programma, anche attraverso il Technical & Community Steering Committee (TCSC), secondo le modalità definite nei documenti di governance,

contribuendo alla definizione degli indirizzi evolutivi del programma.

Gli Aderenti possono:

- proporre evoluzioni;
- contribuire al codice;
- partecipare al Technical & Community Steering Committee.

Per **diventare Aderente**, è necessario inoltrare al Maintainer una richiesta di adesione, secondo le modalità da questo indicate, corredata dal modulo contenente i dati e le dichiarazioni richiesti, mediante il quale il soggetto formalizza l'accettazione delle regole della Community e indica, ove già individuato, il tipo di contribuzione ipotizzato.

L'adesione è subordinata alla verifica da parte del Maintainer della completezza della richiesta e dell'accettazione delle regole della Community. Lo status di Aderente è acquisito a seguito dell'esito positivo di tale verifica.

La verifica del Maintainer ha carattere esclusivamente formale e organizzativo ed è finalizzata ad accertare la completezza della richiesta, l'accettazione delle regole della Community e la coerenza della partecipazione con l'ambito del programma UNICA. Essa non comporta valutazioni discrezionali sul soggetto richiedente né limitazioni al principio di apertura della Community.

Un Aderente può **rinunciare allo status** tramite richiesta motivata al Maintainer, che ne informa il TCSC. La richiesta di uscita non può essere rifiutata. Dopo l'uscita, l'Aderente può continuare a contribuire come Contributore.

La rinuncia comporta la perdita dei diritti di partecipazione al TCSC e degli eventuali ruoli assegnati.

Lo status di Aderente può essere revocato dal TCSC, su proposta del Maintainer, che ne monitora costantemente il comportamento al fine di verificare che la partecipazione dello stesso segua requisiti stabiliti dalla Community. Costituiscono, in particolare, presupposti di revoca la mancata partecipazione attiva e continuativa o la grave violazione delle regole. Prima dell'adozione della decisione, è inviata all'interessato una comunicazione preventiva, al fine di consentirgli di presentare eventuali osservazioni al TCSC entro un termine di tempo ragionevole.

La revoca o la cessazione del ruolo di Responsabile di Progetto (Module Lead) non comporta automaticamente la perdita dello status di Aderente. Analogamente, il mantenimento dello status di Aderente non attribuisce di per sé il diritto a ricoprire ruoli

operativi o di coordinamento all'interno del programma.

4.6 Contributori

I contributi sono sottoposti a revisione e accettazione da parte degli organi competenti della community, sotto il coordinamento del Maintainer.

Chiunque può contribuire a UNICA come **Contributore**, anche senza essere Aderente.

I contributori esterni:

- non hanno ruoli decisionali;
- contribuiscono tramite pull request, issue, documentazione;
- accettano le regole di licensing, governance e code of conduct.

5. Regole di contribuzione

La partecipazione è aperta a tutti i soggetti interessati, fermo restando il rispetto delle regole di contribuzione e dei processi di governance del programma.

Tutti i contributi – di Aderenti e Contributori - devono essere trasparenti e documentati secondo le regole pubblicate nell'allegato C del documento.

Non è ammesso condividere e pubblicare codice coperto da vincoli incompatibili o segreti industriali.

Le regole di contribuzione sono anche descritte nel documento CONTRIBUTING.md.

5.1 Modalità di contribuzione

Per tutti, Contributori e Aderenti, è possibile contribuire a UNICA tramite:

- implementazione di codice sorgente;
- redazione di documentazione di prodotto, come ad esempio le specifiche tecniche dei requisiti di prodotto, l'Architecture Design del prodotto, le API guide, le User Guide, le Install Guide;
- esecuzione di test e casi di conformità normativa;
- segnalazione di bug e miglioramenti;
- apporto di soggetti utilizzatori.

Gli ulteriori contributi con cui gli Aderenti possono collaborare sono i seguenti:

1. Contributo di artefatti (codice, documentazione e altro) sviluppato autonomamente dai singoli soggetti al fine di integrarlo nel software.
2. Contributo mediante lo sviluppo di una nuova componente, oppure di una parte di componente;

3. Contributo di nuovi artefatti in collaborazione con altri Aderenti (cosviluppo);
4. Sostegno alla diffusione e al riuso del software nel perimetro della Pubblica Amministrazione, e contributo al miglioramento della qualità del software attraverso la condivisione di use case (es. raccolta requisiti, segnalazione e validazione di issue, test, documentazione e contributi evolutivi), al fine di aumentare la sostenibilità e ridurre la frammentazione del codice;
5. Partecipazione al TCSC (v. *infra*)

La documentazione progettuale predisposta col fine di implementare il prodotto software costituisce parte della knowledge base dell'Aderente. La scelta di pubblicarla o meno è rimessa all'Aderente, d'intesa con il Maintainer. Ad esempio, i documenti di analisi di business, analisi di dettaglio degli use case, i casi di test puntuali, non devono necessariamente essere distribuiti pubblicamente in occasione del rilascio delle diverse versioni del software.

I Contributori possono interagire tramite gli strumenti messi a disposizione mediante i repository pubblici, mentre gli Aderenti possono anche contribuire – oltre a operare direttamente sui **repository GitHub ufficiali** del programma, operando su repository privati messi a tal fine a disposizione e gestiti dal Maintainer, in via temporanea e funzionale alle attività di sviluppo, in coerenza con le strategie di sviluppo gestite con il TCSC e secondo l'organizzazione ivi strutturata anche rispetto all'assegnazione dei diversi Module Lead. Tale modalità e organizzazione sarà in ogni caso resa trasparente e pubblicata sui repository ufficiali, dove anche detti contributi saranno infine pubblicati in open source. Tale processo di contribuzione degli Aderenti si svolge sotto il coordinamento e la supervisione del Maintainer, che ne garantisce la coerenza tecnica, normativa e qualitativa.

L'accettazione e la gestione dei contributi dei Contributori sono subordinate al rispetto delle regole di cui alle Linee guida e all'accettazione del Maintainer, ove necessario previa consultazione del TCSC.

5.2 Documentazione di programma

La documentazione di programma è composta dai seguenti documenti, disponibili sul repository ufficiale in CC BY 4.0:

- **Work Breakdown Structure** del programma UNICA: suddivisione

dettagliata delle attività e dei deliverable previsti per lo sviluppo e la gestione del software, utile a definire le responsabilità e facilitare il monitoraggio dell'avanzamento del progetto.

- **Organization Breakdown Structure** di programma: rappresenta la suddivisione delle responsabilità organizzative all'interno di un progetto, facilitando la gestione e il controllo delle attività.
- **Tabella RACI** (Responsible, Accountable, Consulted, Informed) per la definizione e la gestione dei ruoli nel programma e nei progetti, utilizzata sia in presentazioni che in documenti operativi e guide, al fine di chiarire responsabilità e competenze all'interno dell'organizzazione.
- La documentazione di programma è condivisa con il TCSC che ne verifica l'aggiornamento e la coerenza con gli indirizzi strategici indicati.

Gli Aderenti tramite il TCSC possono contribuire all'evoluzione della documentazione e sottoporre altro materiale documentale che potrà essere implementato, previa accettazione del Maintainer, a condizione di rilascio con licenza sempre CC BY 4.0.

5.3 Aspetti di licensing

I contributi di Aderenti e Contributori, per essere ammessi, devono sempre e in ogni caso rispettare le seguenti condizioni:

- Tutto il codice sorgente deve essere rilasciato sotto la licenza del progetto. Eventuali rilasci binari o pacchetti distribuiti nell'ambito del programma devono essere accompagnati dalle informazioni di licenza e resi disponibili in conformità alla licenza applicabile al codice sorgente (EUPL 1.2, salvo diversa indicazione).
- Tutta la documentazione di prodotto deve essere rilasciata sotto licenza Creative Commons CC BY 4.0.
- Deve utilizzare il **Developer Certificate of Origin (DCO)**.
- L'invio di contributi tramite repository implica l'applicazione del Developer Certificate of Origin (DCO) di cui al paragrafo successivo.
- L'eventuale modifica della licenza di riferimento della suite UNICA o della documentazione di programma è valutata dal Maintainer sotto il profilo tecnico, giuridico e di sostenibilità, previa consultazione

del TCSC. Le relative decisioni sono motivate e rese pubbliche.

5.4 Developer Certificate of Origin

Il DCO (o **Signed-off-by)**, è una autocertificazione effettuata per ogni commit, in cui il committer (soggetto individuale o dipendente di un Aderente o Contributore che vuole contribuire) in questo modo dichiara che almeno una delle seguenti condizioni è vera:

a) Il contributo è stato creato in tutto o in parte dal Committer e questi ha il diritto e/o l'autorizzazione di presentarlo secondo la licenza open source richiesta; oppure
b) Il contributo si basa su un lavoro precedente che è coperto da un'apposita licenza open source e ho il diritto, in base a tale licenza, di presentare tale lavoro con modifiche, create in tutto o in parte da me, secondo la licenza open source richiesta dalle regole della community UNICA; oppure
c) Il contributo è stato fornito al committer direttamente da un altro soggetto che ha certificato (a), (b) o (c) e non l'ha modificato.

Gli Aderenti garantiscono internamente l'autorizzazione dei propri dipendenti (es. policy interna o dichiarazione), ferma restando l'applicazione del DCO.

Il trattamento dei dati personali connessi alla partecipazione alla Community, incluse le attività di contribuzione, revisione, gestione delle issue, delle pull request e delle dichiarazioni DCO, è effettuato nel rispetto della normativa applicabile in materia di protezione dei dati personali. Le informazioni di dettaglio sono riportate nell'informativa privacy resa disponibile dal Maintainer attraverso i repository ufficiali del programma.

Comunque, e in ogni caso il Contributore:

- deve comprendere e accettare che la community e il contributo così condiviso sono pubblici e che una registrazione del contributo (incluse tutte le informazioni personali che il committer invii insieme ad esso, compresa la firma) viene conservata a tempo indeterminato e può essere ridistribuita in conformità con questo progetto o con le licenze ad esso applicabili;
- deve dichiarare sotto la propria responsabilità che contributo non è coperto da vincoli incompatibili o segreti industriali.

Il DCO permette di:

- garantire tracciabilità giuridica del codice;
- evitare l'ingresso di codice con provenienza dubbia;
- tutelare il Maintainer e tutti gli utilizzatori;
- rispettare la coerenza con il principio di responsabilità del contributore.

6. Regole di gestione del codice

Il codice sorgente del programma UNICA è gestito attraverso repository **GitHub** ufficiali, che costituiscono l'unico punto di riferimento per lo sviluppo collaborativo.

L'eventuale utilizzo di repository privati da parte del Maintainer o degli Aderenti ha natura temporanea, strumentale e non sostitutiva rispetto ai repository GitHub ufficiali, che restano il punto di riferimento per la pubblicazione, la tracciabilità e la distribuzione del codice del programma UNICA.Ogni modifica al codice richiesta da un contributore esterno avviene tramite **pull request**, che devono essere collegate a una issue o a una RFC e sottoposte a revisione da parte di più membri della community, che sono coinvolti a discrezione del module lead. Nessuna modifica viene integrata senza una valutazione tecnica formale e senza il superamento dei controlli automatici previsti (build, test, verifiche di sicurezza e licensing).

I contributi realizzati dagli Aderenti possono essere gestiti sul repository del Maintainer, condiviso, o sul repository ufficiale GitHub. Nel primo caso i rilasci ufficiali del software sul repository GitHub sono effettuati dal Maintainer o da soggetti da esso delegati, seguendo criteri di versionamento semantico e accompagnati da documentazione di rilascio, note di migrazione e materiali di supporto. Questo processo strutturato garantisce stabilità agli Enti utilizzatori e, allo stesso tempo, consente un'evoluzione continua del software.

6.1 Repository ufficiali

Il codice di UNICA è ospitato su repository GitHub ufficiali, gestiti dal Maintainer, a partire dall'organization esistente: https://github.com/unica-open

Ogni repository contiene almeno:

- README.md
- PUBLICCODE.YAML
- LICENSE
- CONTRIBUTING.md

- CODE_OF_CONDUCT.md
- SECURITY.md
- AUTHORS.txt
- SBOM.csv
- DCO.md

6.2 Pull Request

Le **pull request (PR)** sono il meccanismo esclusivo di integrazione del codice.

Regole principali:

- nessuna PR viene accettata senza revisione da parte del module lead;
- sono necessarie **almeno due approvazioni**, di cui una da parte del Module Lead; nelle fasi iniziali del programma o in presenza di motivate esigenze organizzative, il Maintainer può autorizzare l'integrazione sulla base di una sola approvazione qualificata del Module Lead o del Maintainer stesso.
- le PR devono:
    - essere collegate a una issue o RFC;
    - superare i controlli automatici (build, test, sicurezza, licensing);
    - includere documentazione adeguata.

Il Module Lead, o il Maintainer, può rifiutare una PR motivando pubblicamente la decisione.

6.3 Rilasci software

Il codice segue delle regole di pubblicazione stabilite:

- I rilasci ufficiali sono effettuati dal Maintainer o da chi da esso delegato.
- Il versionamento segue le regole del **Semantic Versioning (SEMVER)**.
- Ogni rilascio è accompagnato da:
    - note di rilascio, con indicati gli aggiornamenti specifici del rilascio ad integrazione delle informazioni dei rilasci precedenti.
    - SBOM.csv (Software Bill of Materials, con indicate le librerie di terze parti incluse nel software e le licenze e il copyright associato ad ogni libreria).
    - Aggiornamento dei documenti di prodotto contenuti nel repository (README.md, PUBLICCODE.YAML, AUTHORS.txt).

- indicazioni di compatibilità e migrazione del software e dei dati.
- Istruzioni per la compilazione, l'installazione e la dichiarazione di tutte dipendenze da altri software per garantire la trasparenza all'uso del software da soggetti interessati all'uso.

6.4 Repository privati

I repository privati, gestiti dal Maintainer, servono per condividere e gestire il codice tra i partner nelle fasi di sviluppo, fino al rilascio sul primo ambiente di esercizio. Entro un mese dalla messa in esercizio, salvo impedimenti tecnici, di sicurezza o organizzativi motivati e documentati, il codice, la documentazione essenziale e le informazioni di rilascio dovranno essere pubblicati nei repository pubblici ufficiali.

Questa gestione facilita tempi e attività dei partner, protegge la conoscenza del software da parte dei partner della community e garantisce la necessaria trasparenza a seguito della pubblicazione del codice entro tempi brevi.

6.5 Fork

Il fork è consentito nei limiti della licenza open source; tuttavia, i soggetti che sviluppano varianti non condivise con la community non partecipano ai processi di governance del programma

Al contrario, è consentito ampliare il software creando add-on, funzionalità specifiche, estensioni per client o server, ecc., che potranno essere condivise con la community, nel rispetto delle regole di contribuzione, oppure potranno essere distribuite come componenti sotto licenza privata.

Le estensioni o componenti distribuite con licenze differenti o private non fanno parte del perimetro ufficiale del programma UNICA, salvo loro successivo conferimento e accettazione secondo le regole di contribuzione e licensing del programma. Tali estensioni devono restare interoperabili e non devono limitare la possibilità di utilizzare, modificare e redistribuire il software open source UNICA.

7. Trasparenza e comunicazione

L'interazione con i contributori avviene secondo un approccio best effort, in modo che:

- Tutte le decisioni rilevanti siano documentate tramite:
  - Issue
  - RFC – Request for Change

  - Verbali e documenti di programma e di progetto.
  - verbali del Technical & Community Steering Committee.

- Le discussioni con i contributori esterni avvengono su canali pubblici (GitHub Discussions, mailing list, community call).
- Le comunicazioni private sono utilizzate in via eccezionale ed esclusivamente per temi di sicurezza, protezione dei dati sensibili, informazioni riservate o altre esigenze di riservatezza, ove possibile, gli esiti principali delle decisioni sono successivamente documentati e resi pubblici in forma compatibile con tali vincoli.

Le interazioni avvengono, ove possibile, **entro un mese** dalla richiesta e comunque compatibilmente con la complessità del tema e con le risorse disponibili. L'eventuale mancato riscontro entro tale termine non comporta rigetto automatico della richiesta, che resta valutabile secondo le regole e le priorità del programma.

Anche in presenza di fasi di sviluppo gestite su repository privati, le decisioni e gli esiti principali sono resi pubblici secondo le modalità sopra indicate

8. Code of Conduct

La community UNICA adotta un **Codice di Condotta** ispirato ai migliori standard internazionali (Apache, Contributor Covenant).

Il documento di code of conduct è riportato in Allegato A, e si ispira ai seguenti **Principi fondamentali:**

- rispetto reciproco;
- inclusione e non discriminazione;
- collaborazione costruttiva;
- responsabilità individuale.

Mentre i **Comportamenti non ammessi** sono:

- linguaggio offensivo o discriminatorio;
- molestie o intimidazioni;
- abuso di ruoli o privilegi;
- utilizzo della community per fini estranei o in contrasto con gli obiettivi del programma.

Il codice di condotta si applica a tutti i contributori e il Maintainer, con il supporto

del Technical & Community Steering Committee, può:

- richiamare formalmente un membro;
- sospendere o revocare diritti di contribuzione;
- attivare le eventuali misure di revoca dello status di Aderente.

Le decisioni sono sempre **motivate e documentate;** le modalità operative di gestione delle segnalazioni e delle eventuali violazioni sono definite nell'Allegato A.

9. Sicurezza e divulgazione responsabile

La gestione della sicurezza è un elemento centrale della governance del programma UNICA. Le vulnerabilità o le problematiche di sicurezza devono essere segnalate in modo riservato, evitando la divulgazione pubblica fino alla disponibilità di una mitigazione adeguata. Il Maintainer coordina il processo di analisi, risoluzione e comunicazione delle vulnerabilità, coinvolgendo quando necessario i partner e gli Enti interessati. Questo approccio di **responsible disclosure** consente di proteggere gli utilizzatori del software senza compromettere la trasparenza e la fiducia della community.

Tutti i partecipanti alla community, inclusi Aderenti e contributori, sono tenuti a rispettare le modalità di segnalazione sopra indicate.

9.1 Vulnerabilità

Le vulnerabilità devono essere segnalate **in modo riservato**, secondo quanto indicato nel file SECURITY.md, riportato nell'allegato B.

La divulgazione pubblica avviene solo dopo:

- analisi dell'impatto;
- disponibilità di una mitigazione o fix;
- coordinamento con il Maintainer.

9.2 Gestione dei rischi di divulgazione

La gestione dei rischi della Community UNICA è parte integrante del modello di governance del programma e si fonda su un presidio continuo dei principali profili tecnici, giuridici, organizzativi e di sicurezza. Il Maintainer, con il supporto dell'OSPO, dei Module Lead e, ove necessario, del Technical & Community Steering Committee, presidia, per quanto di competenza, i processi di identificazione, valutazione e trattamento dei rischi connessi all'evoluzione della soluzione, alla qualità del codice, alla compatibilità delle licenze, alla presenza di vulnerabilità, alla

tutela delle informazioni riservate e alla sostenibilità complessiva dei contributi. A tal fine, ogni proposta evolutiva, pull request o nuovo modulo è sottoposto a controlli proporzionati al relativo impatto, anche attraverso verifiche automatiche, revisione tecnica, tracciabilità delle decisioni, produzione e aggiornamento della SBOM e rispetto delle regole di responsible disclosure. Tale approccio consente di ridurre il rischio di frammentazione, lock-in tecnologico, introduzione di componenti non conformi o non manutenibili, assicurando al tempo stesso trasparenza, responsabilità condivisa e continuità evolutiva del patrimonio software pubblico.

Particolare attenzione è riservata al rischio di pubblicazione di documentazione non pubblicabile, contenente informazioni riservate, dati personali, elementi soggetti a vincoli contrattuali, segreti tecnici o industriali, dettagli di sicurezza, credenziali, configurazioni sensibili o contenuti non compatibili con le licenze adottate dal programma. Prima della pubblicazione sui repository ufficiali, ogni documento deve essere sottoposto a una verifica preventiva da parte del soggetto proponente e, ove necessario, del Maintainer, con il supporto delle funzioni competenti. Qualora venga rilevata la presenza di contenuti non pubblicabili, la documentazione deve essere corretta, anonimizzata, oscurata o esclusa dalla pubblicazione. In caso di pubblicazione accidentale, il Maintainer coordina, per quanto di competenza, la tempestiva adozione delle misure di rimozione, contenimento e tracciamento dell'evento, documentando le azioni intraprese e valutando eventuali interventi correttivi sui processi di revisione.

10. Avvio di un nuovo progetto UNICA

Il programma UNICA è concepito come un ecosistema in evoluzione, aperto all'inserimento di nuovi progetti o moduli che rispondano alle esigenze della contabilità pubblica. L'avvio di un nuovo progetto avviene tramite una proposta formale, che descriva obiettivi, ambito funzionale, benefici per la community e sostenibilità nel tempo. La proposta è preliminarmente valutata dal Maintainer sotto il profilo tecnico, normativo e di sostenibilità, e successivamente sottoposta al TCSC per approvazione. In caso di approvazione, il progetto entra ufficialmente nel programma UNICA e viene nominato un **Responsabile di Progetto**, o *Module lead*, secondo le modalità previste all'art. 4.4, che coordina lo sviluppo in

collaborazione con la community e sotto la supervisione del Maintainer.

Questo meccanismo consente di ampliare progressivamente il perimetro di UNICA mantenendo coerenza e qualità complessiva.

10.1 Proposta di nuovo progetto

Un nuovo progetto può entrare nel programma UNICA tramite una **proposta formale**, che includa:

- obiettivi e ambito;
- coerenza con il dominio contabile della PA;
- benefici per la community;
- soggetto proponente.

10.2 Valutazione

La proposta è valutata da:

- Maintainer;
- Technical & Community Steering Committee.

I criteri includono:

- allineamento normativo;
- sostenibilità nel tempo;
- apertura e riusabilità;
- effort e tempi di realizzazione del nuovo modulo proposto.

L'esito della valutazione, sia in caso di approvazione sia di diniego, è motivato e reso pubblico.

10.3 Attribuzione del Responsabile

Il Maintainer e il TCSC possono valutare la dismissione o l'uscita dal programma di progetti non più attivi o sostenibili.

Per ogni nuovo progetto UNICA:

- viene nominato un **Responsabile di Progetto/Module lead**;
- il Responsabile può essere un qualunque rappresentante del Maintainer o degli Aderenti;
- il Maintainer resta garante ultimo.

11. Disposizioni finali

Le presenti regole costituiscono il riferimento ufficiale per la partecipazione alla community open source del programma UNICA. Esse si applicano a tutti i progetti e a tutti i partecipanti, indipendentemente dal ruolo ricoperto. Le regole possono essere aggiornate nel tempo per rispondere all'evoluzione normativa, tecnologica o organizzativa, secondo un processo trasparente che prevede il coordinamento del Maintainer e il coinvolgimento del Technical & Community Steering Committee e la pubblicazione delle modifiche. In questo modo, la

governance di UNICA rimane dinamica e adattabile, senza perdere i principi fondanti di apertura, collaborazione e responsabilità condivisa.

L'utilizzo del software avviene secondo le modalità tipiche dei progetti open source; eventuali livelli di servizio, supporto o manutenzione sono definiti tramite accordi specifici tra gli Enti e i soggetti coinvolti.

Allegato A – Code of Conduct

Ogni comunità sociale richiede regole di convivenza. È importante definire un Code of Conduct che indichi le regole per sviluppatori e utilizzatori.

Gestire e contribuire ad una community significa rendere il gruppo di lavoro virtuale rispettoso delle regole condivise dal Maintainer della community. Per questo motivo, pubblicare un codice di condotta non basta: occorre anche farlo rispettare e, ogni volta che emerga una violazione o una possibile violazione, è importante spiegare perché il suo rispetto è utile a tutti i partecipanti. Il "code of conduct" deve essere inteso come un insieme di regole di comportamento condivise e vincolanti ai fini della partecipazione alla community.

Un esempio, che molte community adottano, è quello della "Contributor Covenant" il cui testo è disponibile già tradotto in varie lingue. Si riporta il testo in lingua italiana (quello in lingua inglese è disponibile al link https://www.contributor-covenant.org/version/2/1/code_of_conduct)

La versione proposta dalla Community UNICA è basata sulla versione 2.1 del Contributor Covenant.

```
# Codice di Comportamento del Collaboratore

## Il Nostro Impegno

Nell'interesse della promozione di un ambiente aperto e accogliente, noi contributori e manutentori ci impegniamo a rendere la partecipazione alla nostra comunità un'esperienza libera da molestie per tutti, indipendentemente dall'età, corporatura, disabilità visibile o meno, etnia, caratteristiche sessuali, identità ed espressione di genere, livello di esperienza, istruzione, stato socio-economico, nazionalità, aspetto, razza, casta, colore della pelle, religione o identità e orientamento sessuale.

Noi ci impegniamo ad agire ed interagire per costruire una comunità aperta, accogliente, diversificata, inclusiva e sana.
```

I nostri Standard

Esempi di comportamenti che contribuiscono alla creazione di un ambiente positivo per la nostra comunità:

* Dimostrare empatia e gentilezza verso le altre persone

* Rispettare le opinioni, i punti di vista ed esperienze differenti

* Fornire, con garbo, critiche costruttive

* Prendersi la responsabilità di quanto sostenuto e scusarsi verso le persone colpite dai nostri sbagli, imparando da queste esperienze

* Concentrarsi non su ciò che è meglio per noi come individui, ma su ciò che è meglio per la comunità

Esempi di comportamento inaccettabile:

* L'uso di linguaggio o immagini sessualizzate e l'attenzione sessuale o avance indesiderate

* Comportamenti da troll, commenti offensivi e attacchi personali o politici

* Molestie in pubblico o in privato

* Pubblicazione di informazioni private altrui, ad esempio un indirizzo postale o elettronico, senza autorizzazione esplicita

* Altri comportamenti che potrebbero ragionevolmente essere considerati inappropriati in un contesto professionale

Adempimento e Responsabilità

Il Maintainer, o soggetti da esso delegali, con il supporto del TCSC è responsabile del chiarimento e dell'applicazione degli standard di comportamento accettabili ed è tenuto a intraprendere azioni correttive appropriate ed eque in risposta a qualsiasi caso di comportamento inaccettabile, minaccioso, offensivo o dannoso.

Il Maintainer, o soggetti da esso delegali, con il supporto del TCSC ha il diritto e la responsabilità di rimuovere, modificare o rifiutare commenti, commit, codice, modifiche dei wiki, issue e altri contributi non allineati a questo Codice di Condotta, comunicando le ragioni dell'intervento di moderazione quando opportuno.

Le attività di applicazione del presente Codice di Condotta sono svolte dal Maintainer, con il supporto del Technical & Community Steering Committee, in coerenza con le disposizioni di governance del programma UNICA.

Scopo

Questo Codice di Comportamento si applica sia all'interno degli spazi della comunità che negli spazi pubblici quando un individuo rappresenta la sua comunità. Esempi di rappresentanza della nostra comunità includono l'uso di un indirizzo e-mail ufficiale del progetto, la pubblicazione tramite un account ufficiale attraverso

social media o la funzione di rappresentante designato ad un evento online o offline.

Applicazione

I casi di comportamento abusivo, molesto o altrimenti inaccettabile possono essere presentati contattando i responsabili dell'applicazione di questo Codice di Condotta della comunità all'indirizzo opensource@csi.it. Tutti i reclami saranno prontamente esaminati ed indagati.

Tutte le guide della comunità sono obbligate a mantenere la riservatezza della persona che ha riportato il caso.

Linee guida all'applicazione

Le guide della comunità seguiranno queste linee guida per determinare le azioni correttive contro azioni che ritengono violare questo Codice di Condotta:

1. Correzione

Impatto nella comunità: Uso di linguaggio inappropriato o altri comportamenti giudicati non professionali o ostili nella community.

Conseguenze: Un avviso scritto in forma privata dalle guide della comunità, spiegando la natura della violazione e perché il comportamento era inappropriato. Pubbliche scuse potrebbero essere richieste.

2. Avviso

Impatto nella comunità: Una violazione dopo un episodio avvenuto o una serie di azioni negative.

Conseguenze: Un avviso per il comportamento perpetrato. Nessuna comunicazione per un periodo di tempo specificato con le persone coinvolte, incluse quelle che applicano il Codice di Condotta. Questo comprende l'inibizione alla partecipazione negli spazi della comunità come canali esterni quali i social media. Violare questi termini può portare ad una espulsione temporanea o permanente.

3. Espulsione temporanea

Impatto nella comunità: Una grave violazione agli standard della comunità, incluso mantenere un comportamento inappropriato.

Conseguenze: Espulsione temporanea per un periodo di tempo specificato a qualsiasi sorta di interazione o comunicazione con la comunità. Durante questo periodo non è permesso nessun dialogo pubblico o privato con le persone coinvolte, comprese coloro che applicano il Codice di Condotta. Violare questi termini può portare ad una espulsione permanente.

4. Espulsione permanente

Impatto nella comunità: Dimostrare sistematicamente di violare gli standard della comunità, inclusa la ripetizione di comportamenti

inappropriati, molestie o aggressioni individuali o denigrazione di gruppi di individui.

Conseguenze: Espulsione permanente da ogni interazione pubblica della comunità.

Attribuzione

Questo Codice di Comportamento è adattato dal Contributor Covenant, versione 2.1, disponibile all'indirizzo https://www.contributor-covenant.org/version/2/1/code_of_conduct.

Le linee guida all'applicazione sono state ispirate dal codice di condotta di Mozilla [Mozilla CoC].

Per riposte a domande comuni riguardo questo codice di condotta, consultare le domande frequenti al link https://www.contributor-covenant.org/faq. Le traduzioni sono disponibili al link https://www.contributor-covenant.org/translations][translations.

homepage: https://www.contributor-covenant.org

v2.1: https://www.contributor-covenant.org/version/2/1/code_of_conduct

Mozilla CoC: https://github.com/mozilla/diversity

FAQ: https://www.contributor-covenant.org/faq

translations: https://www.contributor-covenant.org/translations

Allegato B – Security

Security Policy – Programma UNICA

1. Scopo del documento

Il presente documento definisce le modalità di **gestione delle vulnerabilità di sicurezza** relative al software open source del programma **UNICA** (incluse le componenti **Contabilia**, **Accrual** e ogni altro modulo eventualmente integrato nel programma).

L'obiettivo della presente policy è garantire che eventuali problematiche di sicurezza siano gestite in modo **responsabile, coordinato e trasparente**, tutelando:

- gli Enti utilizzatori del software;

- la community di sviluppo;

- l'affidabilità complessiva dell'ecosistema UNICA.

La gestione della sicurezza è considerata parte integrante della **governance del progetto**, in coerenza con le buone pratiche internazionali in ambito open source.

---

2. Ambito di applicazione

Questa Security Policy si applica a:

- tutti i repository ufficiali del programma UNICA;

- tutto il codice sorgente, la configurazione e la documentazione pubblicata;

- le dipendenze software incluse nei progetti, per quanto di competenza del Maintainer.

Sono considerati **eventi di sicurezza**, a titolo esemplificativo e non esaustivo:

- vulnerabilità applicative critiche (es. OWASP Top 10);

- vulnerabilità applicative non critiche;

- falle di sicurezza note nelle dipendenze software;

- configurazioni non sicure che possano esporre dati o servizi;

- errori che possano compromettere integrità, riservatezza o disponibilità del sistema.

La presente Security Policy si integra con il modello di governance del programma UNICA, come definito nel documento principale, in particolare per quanto riguarda ruoli, responsabilità e processi decisionali.

---

3. Principi di gestione delle vulnerabilità

Il programma UNICA adotta un approccio di **Responsible Disclosure**, basato sui seguenti principi:

- **riservatezza nella fase iniziale** di segnalazione e analisi;

- **tempestività** nella valutazione dell'impatto;

- **proporzionalità** delle azioni correttive rispetto al rischio;

- **trasparenza verso la community**, una volta rese disponibili le mitigazioni.

In nessun caso è incoraggiata la divulgazione pubblica immediata di una vulnerabilità senza aver dato la possibilità al Maintainer di analizzarla e mitigarla.

---

4. Segnalazione delle vulnerabilità

Le vulnerabilità sono classificate secondo livelli di gravità (es. critico, alto, medio, basso), in base a metriche standard riconosciute, al fine di definire priorità e tempi di intervento

Le vulnerabilità **NON devono essere segnalate tramite issue pubbliche**.

Per segnalare una vulnerabilità di sicurezza è necessario utilizzare **esclusivamente il canale riservato** indicato di seguito:

security.opensource@csi.it segnalando nell'oggetto della mail il nome del repository su cui è stata individuata la vulnerabilità:

La segnalazione dovrebbe includere:

- una descrizione chiara della vulnerabilità;

- il modulo o repository interessato;

- gli scenari di impatto potenziale;

- eventuali passi per riprodurre il problema;

- riferimenti a CVE o advisory noti, se applicabili.

Le segnalazioni anonime sono comunque accettate ma valutate sulla base delle informazioni tecniche disponibili e della verificabilità della segnalazione.

---

5. Gestione interna della segnalazione

A seguito di una segnalazione:

1. il **Maintainer (CSI Piemonte)** prende in carico la segnalazione, coordinando le attività con i responsabili del modulo interessato e, ove necessario, con il TCSC;

2. viene effettuata una **valutazione preliminare del rischio** (gravità, impatto, probabilità);

3. se necessario, vengono coinvolti:

   - i responsabili del modulo interessato;

   - l'OSPO del CSI e dei partner;

   - esperti di sicurezza o fornitori competenti;

4. viene definita una **strategia di mitigazione o correzione**;

5. la correzione viene sviluppata, testata e verificata.

In presenza di vulnerabilità critiche o con impatti rilevanti sugli Enti utilizzatori, il Maintainer attiva un processo di escalation, coinvolgendo il TCSC e, se necessario, ulteriori soggetti competenti per la gestione coordinata dell'incidente.

Durante questa fase, al segnalante può essere richiesto supporto o chiarimenti, nel rispetto della riservatezza.

---

6. Tempistiche di risposta

Il programma UNICA si impegna, **ove possibile**, a rispettare le seguenti tempistiche indicative:

- **conferma di ricezione**: entro 5 giorni lavorativi, in caso di segnalazioni non anonime;

- **valutazione preliminare**: entro 10 giorni lavorativi;

- **piano di mitigazione**: definito in funzione della gravità.

Tali tempistiche non costituiscono uno SLA contrattuale, ma rappresentano un impegno verso la community e gli Enti utilizzatori.

---

7. Divulgazione pubblica e fix

Una volta disponibile una soluzione o una mitigazione:

- il fix viene integrato nel codice secondo le normali procedure di sviluppo;

- viene rilasciata una **nuova versione del software**, ove necessario;

- la vulnerabilità viene **comunicata pubblicamente** tramite:

  - note di rilascio;

  - advisory sul repository;

  - eventuali comunicazioni dirette agli Enti interessati.

La divulgazione pubblica **non precede** la disponibilità di una mitigazione, salvo casi eccezionali di rischio elevato già noto pubblicamente.

Le decisioni principali relative alla gestione delle vulnerabilità, ove non soggette a vincoli di riservatezza, sono documentate e rese disponibili alla community secondo i principi di trasparenza del programma.

---

8. Sicurezza preventiva e controlli automatici

Il programma UNICA adotta misure preventive di sicurezza, tra cui:

- analisi statiche del codice;

- controlli sulle dipendenze software;

- utilizzo di strumenti di scansione delle vulnerabilità;

- aggiornamento periodico delle librerie;

- produzione e mantenimento della **Software Bill of Materials (SBOM)**.

Queste attività sono integrate nei processi di sviluppo e di rilascio, in linea con le pratiche DevSecOps adottate dal CSI Piemonte, in qualità di Maintainer, e degli Aderenti coinvolti nelle rispettive attività.

---

9. Limitazioni di responsabilità

Il software UNICA è distribuito come **software open source** secondo la licenza applicabile.

Il Maintainer e la community non garantiscono l'assenza totale di vulnerabilità, ma si impegnano a gestirle in modo responsabile, trasparente e collaborativo.

Gli utilizzatori sono invitati a:

- mantenere il software aggiornato;

- applicare tempestivamente gli aggiornamenti di sicurezza;

- adottare adeguate misure di protezione nei propri ambienti.

---

10. Aggiornamento della Security Policy

La presente Security Policy può essere aggiornata nel tempo per riflettere l'evoluzione normativa, tecnologica o organizzativa del progetto.

Ogni aggiornamento è tracciato e reso pubblico come parte integrante della documentazione del programma UNICA.

Allegato C – Contributing

Contributing – Programma UNICA

Grazie per l'interesse a contribuire al programma **UNICA**, iniziativa open source per la gestione della contabilità della Pubblica Amministrazione (componenti **Contabilia**, **Accrual** e progetti correlati).

Questo documento definisce le **regole di contribuzione**, con particolare riferimento ai **contributori esterni**, ovvero soggetti che, pur non appartenendo all'organizzazione del Maintainer, contribuiscono attivamente allo sviluppo del software.

---

1. Principi generali di contribuzione

La community UNICA si ispira ai principi delle grandi community open source internazionali:

- **community over code**: il valore principale è la comunità;

- **meritocrazia**: ruoli e responsabilità derivano dai contributi concreti;

- **trasparenza**: codice, decisioni e processi sono pubblici;

- **consenso informato**: le decisioni si costruiscono attraverso il dialogo.

Ogni contributo è considerato un atto di collaborazione verso la community e non un semplice apporto individuale.

---

2. Chi può contribuire

Possono contribuire a UNICA:

- sviluppatori di Enti pubblici;

- partner tecnologici;

- università e centri di ricerca;

- singoli professionisti o aziende interessate.

Non è necessario essere partner formale del programma per proporre contributi.

Tuttavia, l'accettazione dei contributi è subordinata al rispetto delle regole descritte in questo documento.

---

3. Ruolo del committer esterno

Il **committer esterno** è un contributore che:

- propone modifiche significative al codice o alla documentazione;

- partecipa in modo continuativo allo sviluppo;

- dimostra attenzione alla qualità, alla sicurezza e alla coerenza del progetto.

Il committer esterno **non ha poteri di merge diretti** né responsabilità di rilascio.

L'integrazione finale del codice resta in capo al **Maintainer** o ai **Responsabili di Progetto** da esso nominati.

Nel tempo, contributi costanti e di qualità possono portare a un riconoscimento formale all'interno della governance del progetto.

---

4. Tipologie di contributo accettate

Sono benvenuti, tra gli altri, i seguenti contributi:

- miglioramenti o correzioni al codice sorgente;

- estensioni funzionali coerenti con il dominio UNICA;

- test automatici e casi di validazione;

- documentazione tecnica o funzionale;

- segnalazione puntuale di bug e vulnerabilità;

- proposte architetturali tramite RFC.

Ogni contributo deve generare valore per l'intera community e non solo per un singolo contesto applicativo.

---

5. Aspetti legali e di licensing

Tutti i contributi al programma UNICA sono rilasciati sotto la **licenza open source del progetto** (di norma EUPL 1.2).

Prima di contribuire, il committer esterno deve:

- accettare il **Code of Conduct** del progetto;

- garantire di avere i diritti sul codice proposto;

- utilizzare il **Developer Certificate of Origin (DCO)**.

Le pull request prive di DCO valido **non possono essere accettate**.

---

6. Modalità di contribuzione tecnica

Il flusso standard di contribuzione è il seguente:

1. aprire una **issue** per descrivere il problema o la proposta;

2. discutere la soluzione con la community, se necessario;

3. creare un branch dedicato a partire dal branch principale;

4. sviluppare la modifica mantenendo lo stile e le convenzioni del progetto;

5. eseguire test e verifiche locali;

6. aprire una **Pull Request (PR)** descrittiva e documentata.

Le PR devono essere focalizzate, leggibili e facilmente revisionabili.

---

7. Regole per le Pull Request

Ogni Pull Request deve:

- essere collegata a una issue o a una RFC;

- descrivere chiaramente **cosa** cambia e **perché**;

- non includere codice non necessario;

- aggiornare la documentazione, se rilevante;

- superare i controlli automatici di qualità e sicurezza.

Per l'accettazione di una PR sono necessarie:

- almeno **due revisioni positive**;

- di cui **almeno una** da parte del Responsabile di Progetto o del Maintainer.

Nelle fasi iniziali del programma o nei casi in cui non sia ragionevolmente disponibile un secondo revisore, il Maintainer può autorizzare l'accettazione della PR sulla base di una sola revisione qualificata, dandone adeguata evidenza nella documentazione della pull request.

Il Maintainer può richiedere modifiche o rifiutare una PR, motivando la decisione.

---

8. Qualità, sicurezza e standard

I committer esterni sono tenuti a:

- rispettare gli standard di codifica del progetto;

- evitare l’introduzione di dipendenze non necessarie;

- non includere dati sensibili o informazioni riservate;

- prestare attenzione agli aspetti di sicurezza applicativa.

Il progetto UNICA integra controlli automatici e semiautomatici su:

- qualità del codice;

- vulnerabilità note;

- compatibilità delle licenze.

Una PR che introduca criticità di sicurezza o licensing non verrà accettata.

---

9. Collaborazione con il Maintainer e lo Steering Committee

I committer esterni collaborano con il Maintainer e, quando opportuno, con lo **Steering Committee** del programma UNICA.

Le proposte di evoluzione rilevanti (nuove funzionalità, cambiamenti architetturali) devono essere presentate tramite **RFC (Request for Change)**, in modo da consentire una valutazione condivisa e trasparente.

Questo processo garantisce coerenza, sostenibilità e allineamento normativo del programma.

---

10. Riconoscimento del contributo

I contributi accettati vengono riconosciuti pubblicamente

tramite:

- storico delle pull request;

- note di rilascio;

- file AUTHORS o documentazione equivalente.

---

11. Codice di Condotta

Tutti i committer esterni sono tenuti a rispettare il **Code of Conduct** del progetto.

Comportamenti offensivi, discriminatori o non collaborativi non sono tollerati e possono portare alla sospensione o esclusione dalla community.

---

12. Contatti e supporto

Per domande sul processo di contribuzione:

- consultare la documentazione del repository, qualora disponibile;

- aprire una issue di tipo *question*;

- partecipare ai canali pubblici della community.

Per temi riservati (es. sicurezza), fare riferimento alle modalità indicate nel file `SECURITY.md`.

Grazie per contribuire a **UNICA** e per supportare un ecosistema open source a servizio della Pubblica Amministrazione.